

Part I: Introduction and Classical Cryptography 第一部分：引言与经典密码学

Chapter 1: Introduction 第一章 引言

1.1 Cryptography and Modern Cryptography 密码学与现代密码学

The Concise Oxford English Dictionary (9th ed.) defines cryptography as "the art of writing or solving codes." This is historically accurate, but does not capture the current breadth of the field or its modern scientific foundations. The definition focuses solely on the codes that have been used for centuries to enable secret communication. But cryptography nowadays encompasses much more than this: it deals with mechanisms for ensuring integrity, techniques for exchanging secret keys, protocols for authenticating users, electronic voting, cryptocurrency, and more. Without attempting to provide a complete characterization, we would say that modern cryptography involves the study of mathematical techniques for securing digital information, systems, and distributed computations against adversarial attacks.

《简明牛津英语词典》（第 9 版）将密码学定义为“编写或破解密码的艺术”。这一定义在历史上是准确的，但并未反映出当今该领域的广度，也没有体现其现代科学基础。该定义仅仅着眼于那些数百年来用于实现秘密通信的密码。然而，如今的密码学所涵盖的范围远不止于此：它涉及确保完整性的机制、交换密钥的技术、认证用户的协议、电子投票、加密货币等等。在不企图给出完整刻画的前提下，我们可以说，现代密码学研究的是用以保护数字信息、系统以及分布式计算免受敌手攻击的数学技术。

The dictionary definition also refers to cryptography as an art. Until late in the 20th century cryptography was, indeed, largely an art. Constructing good codes, or breaking existing ones, relied on creativity and a developed sense of how codes work. There was little theory to rely on and, for a long time, no working definition of what constitutes a good code. Beginning in the 1970s and 1980s, this picture of cryptography radically changed. A rich theory began to emerge, enabling the rigorous study of cryptography as a science and a mathematical discipline. This perspective has, in turn, influenced how researchers think about the broader field of computer security.

词典定义还把密码学称作一门艺术。直到 20 世纪后期，密码学在很大程度上确实是一门艺术。构造好的密码、或者破解已有的密码，依赖于创造力以及对密码工作原理的成熟直觉。当时几乎没有什么理论可以依凭，而且在很长一段时间里，并不存在关于“什么样的密码才算好密码”的有效定义。从 20 世纪 70 年代和 80 年代起，密码学的这一面貌发生了根本性的变化。一套丰富的理论开始出现，使得人们能够把密码学作为一门科学和数学学科来严谨地研究。这一视角反过来也影响了研究者对更广泛的计算机安全领域的思考。

Another very important difference between classical cryptography (say, before the 1980s) and modern cryptography relates to its adoption. Historically, the major consumers of cryptography were military organizations and governments. Today, cryptography is everywhere! If you have ever authenticated yourself by typing a password, purchased something by credit card over the Internet, or downloaded a verified update for your operating system, you have used cryptography. And, more and more, programmers with relatively little experience are being asked to "secure" the applications they write by incorporating cryptographic mechanisms.

经典密码学（譬如 20 世纪 80 年代以前）与现代密码学之间的另一个重要差异，在于其使用范围。从历史上看，密码学的主要使用者是军事组织和政府。而今天，密码学无处不在！如果你曾经通过输入口令来认证自己的身份、通过互联网用信用卡购物，或者下载过一个经过验证的操作系统更新，你就使用过密码学。而且，越来越多经验相对欠缺的程序员也被要求在其编写的应用中嵌入密码学机制，以实现“安

全化"。

In short, cryptography has gone from a heuristic set of techniques for ensuring secret communication for a few niche applications to a science that helps secure systems more generally for ordinary people around the world.

简而言之，密码学已经从一套旨在为少数特定应用保证秘密通信的启发式技术，转变为一门更普遍地帮助全世界普通人保护系统安全的科学。

Goals of this book. Our goal is to make the basic principles of modern cryptography accessible to students of computer science, electrical engineering, or mathematics; to professionals who want to incorporate cryptography in systems or software they are developing; and to anyone with a basic level of mathematical maturity who is interested in understanding this fascinating field. After completing this book, the reader should appreciate the security guarantees common cryptographic primitives are intended to provide; be aware of standard (secure) constructions of such primitives; and be able to perform a basic evaluation of new schemes based on their proofs of security (or lack thereof) and the mathematical assumptions underlying those proofs. It is not our intention for readers to become experts—or to be able to design new cryptosystems—after finishing this book, but we have attempted to provide the terminology and foundational material needed for the interested reader to subsequently study the more advanced literature in this field.

本书的目标。我们的目标是让现代密码学的基本原理能够为计算机科学、电气工程或数学专业的学生、希望在自己开发的系统或软件中引入密码学的专业人士，以及任何具备基本数学成熟度并有意了解这一迷人领域的人所理解。在读完本书之后，读者应当能够领会常见密码学原语旨在提供的安全保证，了解这些原语的标准（安全）构造，并能够基于安全性证明（或其缺失）以及这些证明所依赖的数学假设，对新方案做出基本评估。我们并不指望读者在读完本书后就能成为专家——或能够设计新的密码系统——但我们力图提供必要的术语和基础材料，使有心的读者随后能够研读本领域更高级的文献。

This chapter. The focus of this book is the formal study of modern cryptography, but we begin in this chapter with a more informal discussion of "classical" cryptography. Besides allowing us to ease into the material, our treatment in this chapter will also serve to motivate the more rigorous approach we will be taking in the rest of the book. Our intention here is not to be exhaustive and, as such, this chapter should not be taken as a representative historical account. The reader interested in the history of cryptography is invited to consult the references at the end of this chapter.

本章导读。本书的核心是现代密码学的形式化研究，但我们在本章先以较为非正式的方式讨论“经典”密码学。这样做除了让我们能循序渐进地进入正题，本章的处理也将为我们在全书余下部分所采取的更严谨的方法提供动机。我们在此并不追求面面俱到，因此本章不应被当作一份具有代表性的历史叙述。对密码学的历史感兴趣的读者，可以参阅本章末尾所列的参考文献。

1.2 The Setting of Private-Key Encryption 私钥加密的设定

Classical cryptography was concerned with designing and using codes (or ciphers) that enable two parties to send messages while keeping those messages hidden from an eavesdropper who can monitor all communication between them. In modern parlance, codes are called encryption schemes and that is the terminology we will use here. Security of all classical encryption schemes relies on a secret—a key—shared by the communicating parties in advance and unknown to the eavesdropper. This scenario, in which the communicating parties share some secret information in advance, is known as the private-key (or shared-/secret-key) setting, and private-key encryption is one example of a cryptographic primitive used in this setting. Before describing some historical encryption schemes, we discuss private-key encryption more generally.

经典密码学关注的是设计和使用能够让两方发送消息、同时使这些消息对能够监听他们之间所有通信的窃听者保密的密码（或密码体制）。用现代的术语来说，这类密码被称为加密方案，本书也将采用这一术语。所有经典加密方案的安全性都依赖于一个秘密——一个密钥——它由通信双方事先共享，且不为窃听者所知。这种通信双方事先共享某些秘密信息的情形，被称为私钥（或共享密钥/秘密密钥）设定，而私钥加密就是该设定下使用的一种密码学原语。在介绍一些历史上的加密方案之前，我们先更一般地讨论一下私钥加密。

In the context of private-key encryption, two parties share a key and use that key when they want to communicate secretly. One party can send a message, or plaintext, to the other by using the shared key to encrypt (or "scramble") the message and thus obtain a ciphertext that is transmitted to the receiver. The receiver uses the same key to decrypt (or "unscramble") the ciphertext and recover the original message.

在私钥加密的语境下，双方共享一个密钥，并在希望进行秘密通信时使用该密钥。其中一方可以借助共享密钥对消息（即明文）进行加密（或“扰乱”），从而得到一个密文，并将其发送给接收方。接收方使用同一个密钥对密文进行解密（或“还原”），以恢复出原始消息。

【此处为图 1.1】

FIGURE 1.1: One common use case for private-key cryptography (here, encryption): two parties share a key that they use to communicate securely. / 图 1.1: 私钥密码学（此处为加密）的一种常见用例：两方共享一个密钥，并用它来进行安全通信。

The same key is used to convert the plaintext into a ciphertext and back; that is why this setting is also known as the symmetric-key setting, where the symmetry lies in the fact that both parties hold the same key that is used for encryption and decryption. This is in contrast to asymmetric, or public-key, encryption (introduced in Chapter 11), where encryption and decryption use different keys.

同一个密钥既被用于把明文转换为密文，也被用于反向转换；正因如此，这种设定也被称为对称密钥设定，其“对称”之处在于双方持有同一个用于加密和解密的密钥。这与非对称加密（又称公钥加密，在第 11 章介绍）形成对比，后者的加密和解密使用不同的密钥。

As already noted, the goal of encryption is to keep the plaintext hidden from an eavesdropper who can monitor the communication channel and observe the ciphertext. We discuss this in more detail later in this chapter, and spend a great deal of time in Chapters 2, 3, and 5 formally defining this goal.

如前所述，加密的目标是使明文对能够监听通信信道并观察到密文的窃听者保密。我们将在本章稍后更详细地讨论这一点，并在第 2、3、5 章花费大量篇幅正式定义这一目标。

There are two canonical applications of private-key cryptography. In the first (cf. Figure 1.1), the two communication parties are separated in space, e.g., a worker in New York communicating with her colleague in California. These two users are assumed to have been able to securely share a key in advance of their communication. (Note that if one party simply sends the key to the other over the public communication channel, then the eavesdropper obtains the key also!) This could be accomplished, for example, by having the parties physically meet in a secure location to share a key before they separate; in the example just given, the co-workers might arrange to share a key when they are both in the New York office. In other cases, sharing a key securely is more difficult. For the next several chapters we simply assume that sharing a key is possible; we revisit this issue in Chapter 11.

私钥密码学有两种典型的应用场景。第一种（见图 1.1）中，通信双方在空间上是分离的，例如纽约的一位员工与其加利福尼亚的同事通信。我们假定这两位用户在通信之前就已经能够安全地共享一个密钥。

（注意：如果一方只是通过公共通信信道把密钥发送给另一方，那么窃听者也会获得该密钥！）例如，这可以通过让双方在分别之前亲自在一个安全地点会面来共享密钥而实现；在上面给出的例子中，这两位同事可以约定在两人都在纽约办公室时共享一个密钥。在另一些情况下，安全地共享密钥要困难得多。在接下来的几章里，我们简单地假定共享密钥是可行的；我们将在第 11 章重新讨论这一问题。

The second widespread application of private-key cryptography involves the same party communicating with itself over time. (See Figure 1.2.) Consider, e.g., disk encryption, where a user encrypts some plaintext and stores the resulting ciphertext on his hard drive; the same user will return at a later point in time to decrypt the ciphertext and recover the original data. The hard drive here serves as the communication channel on which an attacker might eavesdrop if it can gain access to the hard drive and read its contents. "Sharing" the key is now trivial, though the user still needs a secure and reliable way to remember/store the key for use at a later point in time.

私钥密码学的第二种广泛应用，涉及同一方与自身在不同时间之间的通信。（见图 1.2。）例如考虑磁盘加密：用户加密某些明文，并将所得密文存储在自己的硬盘上；同一个用户会在之后的某个时刻回来解密密文，恢复原始数据。此处的硬盘就充当了通信信道——如果攻击者能够访问硬盘并读取其内容，就可以在该信道上窃听。此时“共享”密钥是轻而易举的，但用户仍然需要一种安全且可靠的方式来记住/存储密钥，以备日后使用。

【此处为图 1.2】

FIGURE 1.2: Another common use case of private-key cryptography (again, encryption): a single user stores data securely over time. / 图 1.2: 私钥密码学（同样以加密为例）的另一种常见用例：单个用户随时间安全地存储数据。

The syntax of encryption. Formally, a private-key encryption scheme is defined by specifying a message space $\mathcal{M}$ along with three algorithms: a procedure for generating keys (Gen), a procedure for encrypting (Enc), and a procedure for decrypting (Dec). The message space $\mathcal{M}$ defines the set of "legal" messages, i.e., those supported by the scheme. The algorithms of the scheme have the following functionality:

加密的语法。形式上，一个私钥加密方案通过指定一个消息空间 $\mathcal{M}$ 以及三个算法来定义：一个生成密钥的过程（Gen）、一个加密的过程（Enc）和一个解密的过程（Dec）。消息空间 $\mathcal{M}$ 定义了“合法”消息的集合，即该方案所支持的那些消息。该方案的算法具有如下功能：

1. The key-generation algorithm Gen is a probabilistic algorithm that outputs a key k chosen according to some distribution.
密钥生成算法 Gen 是一个概率算法，它输出一个按某种分布选取的密钥 k 。
2. The encryption algorithm Enc takes as input a key k and a message m and outputs a ciphertext c . We denote by $\text{Enc}_k(m)$ the encryption of the plaintext m using the key k .
加密算法 Enc 以密钥 k 和消息 m 为输入，输出一个密文 c 。我们用 $\text{Enc}_k(m)$ 表示使用密钥 k 对明文 m 进行的加密。
3. The decryption algorithm Dec takes as input a key k and a ciphertext c and outputs a plaintext m . We denote the decryption of the ciphertext c using the key k by $\text{Dec}_k(c)$.
解密算法 Dec 以密钥 k 和密文 c 为输入，输出一个明文 m 。我们用 $\text{Dec}_k(c)$ 表示使用密钥 k 对密文 c 进行的解密。

An encryption scheme must satisfy the following correctness requirement: for every key k output by Gen and every message $m \in \mathcal{M}$, it holds that

一个加密方案必须满足如下的正确性要求：对于 Gen 输出的每一个密钥 k 以及每一条消息 $m \in \mathcal{M}$ ，都有

$$\text{Dec}_k(\text{Enc}_k(m)) = m.$$

In words: encrypting a message and then decrypting the resulting ciphertext using the same key yields the original message.

换言之：先用某个密钥加密一条消息，再用同一个密钥对所得密文进行解密，将得到原始消息。

The set of all possible keys output by the key-generation algorithm is called the key space and is denoted by $\mathcal{K}$. Almost always, Gen simply chooses a key uniformly from the key space; in fact, one can assume without loss of generality that this is the case (see Exercise 2.1).

密钥生成算法可能输出的所有密钥构成的集合称为密钥空间，记作 $\mathcal{K}$ 。在绝大多数情况下，Gen 只是从密钥空间中均匀地选取一个密钥；事实上，可以不失一般性地假定情况就是如此（见习题 2.1）。

Reviewing our earlier discussion, an encryption scheme can be used by two parties who wish to communicate secretly as follows. First, Gen is run to obtain a key k that the parties share. Later, when one party wants to send a plaintext m to the other, she computes $c := \text{Enc}_k(m)$ and sends the resulting ciphertext c over the public channel to the other party.¹ Upon receiving c , the other party computes $m := \text{Dec}_k(c)$ to recover the original plaintext.

回顾前面的讨论，希望进行秘密通信的双方可以按如下方式使用一个加密方案。首先，运行 Gen 得到一个由双方共享的密钥 k 。之后，当一方想向另一方发送明文 m 时，她计算 $c := \text{Enc}_k(m)$ ，并通过公共信道将所得密文 c 发送给对方。¹ 对方在收到 c 之后，计算 $m := \text{Dec}_k(c)$ 以恢复原始明文。

Keys and Kerckhoffs' principle. As should be clear from the above, if an eavesdropping adversary knows the algorithm Dec as well as the key k shared by the two communicating parties, then that adversary will be able to decrypt any ciphertexts transmitted by those parties. It is for this reason that the communicating parties must share the key k securely and keep k completely hidden from everyone else. Perhaps they should keep the decryption algorithm Dec secret, also? For that matter, would it not be better for them to keep all the details of the encryption scheme secret?

密钥与柯克霍夫原则。从上面的讨论应当清楚：如果一个窃听的敌手既知道算法 Dec，又知道通信双方共享的密钥 k ，那么该敌手就能解密这两方传送的任何密文。正因如此，通信双方必须安全地共享密钥 k ，并把 k 对其他所有人完全保密。那么，他们是不是也应该对解密算法 Dec 保密？就此而言，把加密方案的所有细节都保密，岂不是更好？

Auguste Kerckhoffs [114, 115] argued the opposite in the late 19th century when elucidating several design principles for military ciphers. One of the most important of these, now known simply as Kerckhoffs' principle, was:

奥古斯特·柯克霍夫 (Auguste Kerckhoffs) [114, 115] 在 19 世纪末阐明若干军用密码设计原则时，提出了相反的观点。其中最重要的一条，如今被简称为柯克霍夫原则 (Kerckhoffs' principle)，是这样说的：

The cipher method must not be required to be secret, and it must be able to fall into the hands of the enemy without inconvenience.

密码方法不必要求保密，它必须能够落入敌手而不致造成麻烦。

That is, an encryption scheme should be designed to be secure even if an eavesdropper knows all the details of the scheme, so long as the attacker doesn't know the key being used. Stated differently, security should not rely on the encryption scheme being secret; instead, Kerckhoffs' principle demands that security rely solely on secrecy of the key.

也就是说，一个加密方案应当被设计成即使在窃听者知晓该方案所有细节的情况下也是安全的，只要攻击者不知道所使用的密钥。换言之，安全性不应依赖于加密方案的保密；相反，柯克霍夫原则要求安全性仅仅依赖于密钥的保密。

There are three primary arguments in favor of Kerckhoffs' principle. The first is that it is significantly easier to maintain secrecy of a short key than to keep secret a (more complicated) encryption scheme. This is especially true when encryption is used widely. For example, consider the case where encryption is used for communication between all pairs of employees in some organization. Unless each pair of parties use their own, unique scheme, some parties will know the scheme being used by others. Moreover, information about the scheme might be leaked by one of those employees (say, after being fired), or obtained by an attacker using reverse engineering. In short, it is simply unrealistic to assume that the encryption scheme will remain secret.

支持柯克霍夫原则的主要理由有三条。第一，维持一个短密钥的保密性，要比保守一个（更复杂的）加密方案的秘密容易得多。当加密被广泛使用时尤其如此。例如，考虑加密被用于某个组织中所有员工两两之间通信的情形。除非每一对当事方都使用各自独有的方案，否则一些当事方将会知道其他当事方所使用的方案。此外，关于方案的信息可能被其中某个员工（比如在被解雇之后）泄露，或者被攻击者通过逆向工程获取。简而言之，假定加密方案能够一直保密，是不切实际的。

Second, in case the honest parties' shared, secret information is ever exposed, it will be much easier for them to change the key than to replace the encryption scheme. (Consider updating a file versus installing a new program.) Moreover, it is relatively trivial to generate a new random secret, whereas it would be a huge undertaking to design a new encryption scheme.

第二，一旦诚实方共享的秘密信息暴露，更换密钥要比更换整个加密方案容易得多。（试想更新一个文件与安装一个新程序之间的差别。）此外，生成一个新的随机秘密相对轻而易举，而设计一个新的加密方案则是一项浩大的工程。

Finally, prior to widespread deployment of an encryption scheme, there is a significant benefit to encouraging public review of that scheme in order to check for possible weaknesses. Going further, it is desirable to standardize encryption schemes so that (1) compatibility between different users is ensured and (2) the general public will use strong schemes that have undergone public scrutiny. Overall, perhaps counter-intuitively, it is advantageous to have broad, public dissemination of the full details of an encryption scheme—the exact opposite of keeping the scheme secret.

最后，在一个加密方案被广泛部署之前，鼓励对该方案进行公开审查以检查其可能存在的弱点，是大有裨益的。更进一步，对加密方案进行标准化也是可取的，这样可以：（1）确保不同用户之间的兼容性；（2）让公众使用经过公开审查的强方案。总的来看，也许有些反直觉，但广泛而公开地传播一个加密方案的全部细节是有利的——这与把方案保密恰恰相反。

Nowadays Kerckhoffs' principle is understood as advocating that the entire cryptographic design process be made completely public, in stark contrast to the notion of "security by obscurity" that suggests keeping algorithms secret improves security. In fact, it is very dangerous to use a proprietary, "homebrewed" algorithm (i.e., a non-standardized algorithm designed in secret) since published designs undergo public peer review and are therefore likely to be stronger. Many years of experience have demonstrated that it is very difficult to construct good cryptographic schemes. Our confidence in the security of a scheme is much higher if it has been extensively studied by experts (beyond the designers of the scheme) and no flaws have been found. As simple and obvious as it may sound, the principle of open cryptographic design (i.e., Kerckhoffs' principle) has been ignored over and over again with disastrous results. Fortunately, today there are several secure, standardized, and widely available cryptosystems and no reason to use anything else.

如今，柯克霍夫原则被理解为倡导让整个密码设计过程完全公开，这与“通过隐藏实现安全”（security by obscurity，即认为对算法保密能提高安全性）的观念形成鲜明对比。事实上，使用专有的、“自制”的算法（即在秘密状态下设计的、未经标准化的算法）是非常危险的，因为公开发表的设计会经过公开的同行评审，因此更可能是强健的。多年的经验表明，构造好的密码方案非常困难。如果一个方案经过了专家（方案设计者以外的人）的广泛研究而未发现缺陷，我们对该方案安全性的信心就会高得多。开放密码设计原则（即柯克霍夫原则）听起来虽然简单而理所当然，却一次又一次地被忽视，并造成了灾难性的后果。幸运的是，如今已经有若干安全、标准化且广泛可用的密码系统，没有任何理由去使用别的。

1.3 Historical Ciphers and Their Cryptanalysis 历史密码及其密码分析

In our study of "classical" cryptography we will examine some historical encryption schemes and show that they are insecure. Our main aims in presenting this material are (1) to highlight the weaknesses of heuristic approaches to cryptography, and thus motivate the modern, rigorous approach that will be taken in the rest of the book, and (2) to demonstrate that simple approaches to achieving secure encryption are unlikely to succeed. Along the way, we will present some central principles of cryptography inspired by the weaknesses of these historical schemes.

在我们对“经典”密码学的研究中，将考察若干历史上的加密方案，并说明它们是不安全的。我们介绍这些内容的主要目的是：（1）凸显密码学中启发式方法的弱点，从而引出全书余下部分将要采取的现代、严谨的方法；（2）表明实现安全加密的简单方法不太可能成功。在此过程中，我们还将介绍若干由这些历史方案的缺陷所启发的密码学核心原则。

In this section, plaintext characters are written in lower case and ciphertext characters are written in UPPER CASE for clarity.

在本节中，为清楚起见，明文字符用小写、密文字符用大写表示。

Caesar's cipher. One of the oldest recorded ciphers, known as Caesar's cipher, is described in *De Vita Caesarum, Divus Iulius* ("The Lives of the Caesars, the Deified Julius"), written in approximately 110 CE:

凯撒密码。有记载的最古老的密码之一，即凯撒密码（Caesar's cipher），描述于约公元 110 年写成的《*De Vita Caesarum, Divus Iulius*》（《诸恺撒传·神化的尤利乌斯》）中：

There are also letters of his to Cicero, as well as to his intimates on private affairs, and in the latter, if he had anything confidential to say, he wrote it in cipher, that is, by so changing the order of the letters of the alphabet, that not a word could be made out...

还有他写给西塞罗的信，以及写给密友谈及私事的书信；在后一类信件中，如果他有任何机密之事要讲，他就用密码来写，也就是通过如此改变字母表中字母的顺序，以至于一个字也认不出来.....

Julius Caesar encrypted by shifting the letters of the alphabet 3 places forward: a was replaced with D, b with E, and so on. At the very end of the alphabet, the letters wrap around and so z was replaced with C, y with B, and x with A. For example, encryption of the message begin the attack now, with spaces removed, gives:

尤利乌斯·恺撒通过把字母表中的字母向前移动 3 位来加密：a 被替换为 D，b 被替换为 E，依此类推。在字母表的末尾处字母会回绕，因此 z 被替换为 C、y 被替换为 B、x 被替换为 A。例如，对消息 begin the attack now（去掉空格）进行加密，得到：

EHJLQWKHDWDFNQRZ.

An immediate problem with this cipher is that the encryption method is fixed; there is no key. Thus, anyone learning how Caesar encrypted his messages would be able to decrypt effortlessly.

这种密码的一个直接问题是：其加密方法是固定的，没有密钥。因此，任何了解到恺撒如何加密其消息的人，都能毫不费力地解密。

Interestingly, a variant of this cipher called ROT-13 (where the shift is 13 places instead of 3) is still used nowadays in various online forums. It is understood that this does not provide any cryptographic security; it is used merely to ensure that the text (say, a movie spoiler) is unintelligible unless the reader of a message makes the conscious decision to decrypt it.

有趣的是，这种密码的一个变体，称为 ROT-13（其中移位是 13 位而不是 3 位），如今仍在各种网络论坛中被使用。人们明白它并不提供任何密码学意义上的安全性；它仅仅用来确保文本（例如某部电影的剧透）是不可读的，除非消息的读者有意识地决定去解密它。

The shift cipher and the sufficient key-space principle. The shift cipher can be viewed as a keyed variant of Caesar's cipher.² Specifically, in the shift cipher the key k is a number between 0 and 25. To encrypt, letters are shifted as in Caesar's cipher, but now by k places. Mapping this to the syntax of encryption described earlier, the message space consists of arbitrary length strings of English letters with punctuation, spaces, and numerals removed, and with no distinction between upper and lower case. Algorithm Gen outputs a uniform key $k \in \{0, \dots, 25\}$; algorithm Enc takes a key k and a plaintext and shifts each letter of the plaintext forward k positions (wrapping around at the end of the alphabet); and algorithm Dec takes a key k and a ciphertext and shifts every letter of the ciphertext backward k positions.

移位密码与充分密钥空间原则。移位密码（shift cipher）可以看作凯撒密码的带密钥变体。² 具体而言，在移位密码中，密钥 k 是 0 到 25 之间的一个数。加密时，字母像凯撒密码中那样进行移位，但现在移动 k 位。把它映射到前面描述的加密语法上：消息空间由任意长度的英文字母串构成，其中标点、空格和数字都被去除，并且不区分大小写。算法 Gen 输出一个均匀选取的密钥 $k \in \{0, \dots, 25\}$ ；算法 Enc 以密钥 k 和一个明文为输入，把明文的每个字母向前移动 k 位（在字母表末尾回绕）；算法 Dec 以密钥 k 和一个密文为输入，把密文的每个字母向后移动 k 位。

A more mathematical description is obtained by equating the English alphabet with the set $\{0, \dots, 25\}$ (so $\mathbf{a} = 0$, $\mathbf{b} = 1$, etc.). The message space $\mathcal{M}$ is then any finite sequence of integers from this set. Encryption of the message $m = m_1 \cdots m_\ell$ (where $m_i \in \{0, \dots, 25\}$) using key k is given by

将英文字母表与集合 $\{0, \dots, 25\}$ 等同起来（即 $\mathbf{a} = 0$ 、 $\mathbf{b} = 1$ ，等等），便可得到更数学化的描述。此时消息空间 $\mathcal{M}$ 是取自该集合的整数的任意有限序列。使用密钥 k 对消息 $m = m_1 \cdots m_\ell$ （其中 $m_i \in \{0, \dots, 25\}$ ）进行加密，由下式给出：

$$\text{Enc}_k(m_1 \cdots m_\ell) = c_1 \cdots c_\ell, \quad \text{where } c_i = [(m_i + k) \bmod 26].$$

(The notation $[a \bmod N]$ denotes the remainder of a upon division by N , with $0 \leq [a \bmod N] < N$. We refer to the process mapping a to $[a \bmod N]$ as reduction modulo N ; see also Chapter 9.) Decryption of a ciphertext $c = c_1 \cdots c_\ell$ using key k is given by

（记号 $[a \bmod N]$ 表示 a 除以 N 所得的余数，其中 $0 \leq [a \bmod N] < N$ 。我们把 a 映射到 $[a \bmod N]$ 的过程称为模 N 归约（reduction modulo N ）；另见第 9 章。）使用密钥 k 对密文 $c = c_1 \cdots c_\ell$ 进行解密，由下式给出：

$$\text{Dec}_k(c_1 \cdots c_\ell) = m_1 \cdots m_\ell, \quad \text{where } m_i = [(c_i - k) \bmod 26].$$

Is the shift cipher secure? Before reading on, try to decrypt the following ciphertext that was generated using the shift cipher and a secret key k :

移位密码安全吗？在继续阅读之前，请尝试解密下面这段用移位密码和一个秘密密钥 k 生成的密文：

OVDTHUFVWZZPISLRLFZHYLAOLYL.

Is it possible to recover the message without knowing k ? Actually, it is trivial! The reason is that there are only 26 possible keys. So one can try to decrypt the ciphertext using every possible key and thereby obtain a list of 26 candidate plaintexts. The correct plaintext will certainly be on this list; moreover, if the ciphertext is "long enough" then the correct plaintext will likely be the only candidate on the list that "makes sense." By scanning the list of candidates it is easy to recover the original plaintext. (This is not necessarily true, but will be true most of the time. Even when it is not, this attack narrows down the set of potential plaintexts to at most 26 possibilities.)

在不知道 k 的情况下，能恢复出消息吗？事实上，这轻而易举！原因在于可能的密钥只有 26 个。于是人们可以尝试用每一个可能的密钥去解密该密文，从而得到一份包含 26 个候选明文的列表。正确的明文必定在该列表上；而且，如果密文“足够长”，那么正确的明文很可能是列表上唯一“有意义”的候选。通过浏览候选列表，就能轻松恢复原始明文。（这不一定成立，但在大多数情况下成立。即便不成立，这种攻击也把潜在明文的范围缩小到了至多 26 种可能。）

An attack that involves trying every possible key is called a brute-force or exhaustive-search attack. Clearly, for an encryption scheme to be secure it must not be vulnerable to such an attack.³ This observation is known as the sufficient key-space principle:

那种尝试每一个可能密钥的攻击，被称为穷举攻击 (brute-force attack) 或穷尽搜索攻击 (exhaustive-search attack)。显然，一个加密方案要想安全，就不能对这种攻击束手就擒。³ 这一观察被称为充分密钥空间原则 (sufficient key-space principle)：

Any secure encryption scheme must have a key space that is sufficiently large to make an exhaustive-search attack infeasible.

任何安全的加密方案，其密钥空间都必须足够大，以使穷尽搜索攻击不可行。

One can debate what amount of effort makes a task "infeasible," and an exact determination of feasibility depends on both the resources of a potential attacker and the length of time for which the sender and receiver want to ensure secrecy of their communication. Nowadays, attackers can use supercomputers, thousands of cloud servers, or graphics processing units (GPUs) to speed up brute-force attacks. To protect against such attacks the key space must be very large—say, of size at least 2^{80} , and even larger in many settings.

人们可以争论到底多大的工作量才算使一项任务“不可行”，而对可行性的精确判定，既取决于潜在攻击者的资源，也取决于发送方与接收方希望为其通信保密的时间长度。如今，攻击者可以利用超级计算机、成千上万台云服务器或图形处理器（GPU）来加速穷举攻击。为抵御此类攻击，密钥空间必须非常大——比如说，至少为 2^{80} 量级，在许多场景下甚至要更大。

The sufficient key-space principle gives a necessary condition for security, but not a sufficient one. The next example demonstrates this.

充分密钥空间原则给出了安全性的一个必要条件，但并不是充分条件。下一个例子就说明了这一点。

The mono-alphabetic substitution cipher. In the shift cipher, the key defines a map from each letter of the (plaintext) alphabet to some letter of the (ciphertext) alphabet, where the map is a fixed shift determined by the key. In the mono-alphabetic substitution cipher the key also defines a map on the alphabet, but the map is now allowed to be arbitrary subject only to the constraint that it be one-to-one (so that decryption is possible). The key space thus consists of all bijections, or permutations, of the alphabet. So, for example, the key that defines the following permutation

单表替换密码。在移位密码中，密钥定义了一个从（明文）字母表中每个字母到（密文）字母表中某个字母的映射，其中该映射是由密钥决定的一个固定移位。在单表替换密码（mono-alphabetic substitution cipher）中，密钥同样定义了字母表上的一个映射，但现在该映射可以是任意的，唯一的约束是它必须是一一映射（从而保证可解密）。因此，密钥空间由字母表上所有的双射（即置换）构成。例如，定义如下置换的密钥

a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
X	E	U	A	D	N	B	K	V	M	R	O	C	Q	F	S	Y	H	W	G	L	Z	I	J	P	T

(in which a maps to X, etc.) would encrypt the message tellhimaboutme to GDOOKVCXEFLGCD. The name of this cipher comes from the fact that the key defines a (fixed) substitution for individual characters of the plaintext.

（其中 a 映射到 X，依此类推）会把消息 tellhimaboutme 加密成 GDOOKVCXEFLGCD。该密码的名称正源于此：密钥为明文的单个字符定义了一种（固定的）替换。

Assuming the English alphabet is being used, the key space is of size $26! = 26 \cdot 25 \cdot 24 \cdots 2 \cdot 1$, or approximately 2^{88} , and a brute-force attack is infeasible. This, however, does not mean the cipher is secure! In fact, as we will show next, it is easy to break this scheme even though it has a large key space.

假设使用的是英文字母表，密钥空间的大小为 $26! = 26 \cdot 25 \cdot 24 \cdots 2 \cdot 1$ ，约为 2^{88} ，穷举攻击是不可行的。然而，这并不意味着该密码就是安全的！事实上，正如我们接下来将展示的，即便它拥有巨大的密钥空间，攻破该方案也轻而易举。

Assume English-language text is being encrypted (i.e., the text is grammatically correct English writing, not just text written using characters of the English alphabet). The mono-alphabetic substitution cipher can then be attacked by utilizing statistical properties of the English language. (Of course, the same idea works for any language.) The attack relies on the facts that:

假设被加密的是英文文本（即该文本是语法正确的英文写作，而不仅仅是用英文字母表字符写成的文本）。此时，可以利用英语的统计特性来攻击单表替换密码。（当然，同样的思路对任何语言都适用。）该攻击所依赖的事实是：

1. For any key, the mapping of each letter is fixed, and so if e is mapped to D, then every appearance of e in the plaintext will result in the appearance of D in the ciphertext.
对任何密钥而言，每个字母的映射都是固定的；因此如果 e 被映射到 D，那么明文中每一次出现 e，都会导致密文中出现 D。
2. The frequency distribution of individual letters in English-language text is known. (See Figure 1.3.) Of course, very short texts may deviate from this distribution, but even texts consisting of only a few sentences tend to have distributions that are very close to it.
英文文本中单个字母的频率分布是已知的。（见图 1.3。）当然，非常短的文本可能偏离这一分布，但即便是只包含几句话的文本，其分布往往也与它非常接近。

【此处为图 1.3】

FIGURE 1.3: Average letter frequencies for English-language text. / 图 1.3: 英文文本中字母的平均频率。

The attack works by tabulating the frequency distribution of characters in the ciphertext, i.e., recording that A appeared 12% of the time, B appeared 3% of the time, and so on. These frequencies are then compared to the known letter frequencies of normal English text. One can then guess parts of the mapping defined by the key based on the observed frequencies. For example,

该攻击的工作方式是：先统计密文中各字符的频率分布，即记录 A 出现了 12%、B 出现了 3%，依此类推；然后将这些频率与正常英文文本的已知字母频率进行比较。基于观察到的频率，人们就可以猜测密钥所定义映射的一部分。例如，

since **e** is the most frequent letter in English, one can guess that the most frequent character in the ciphertext corresponds to the plaintext character **e**, and so on. Some of the guesses may be wrong, but enough of the guesses will be correct to enable relatively quick decryption (especially utilizing other knowledge of English, such as the fact that **q** is generally followed by **u**, and that **h** is likely to appear between **t** and **e**). We conclude that although the mono-alphabetic substitution cipher has a large key space, it is still insecure.

由于 **e** 是英语中最常见的字母，人们可以猜测密文中最常出现的字符对应明文字符 **e**，依此类推。其中一些猜测可能是错的，但有足够多的猜测是正确的，足以使解密相对迅速地完成（尤其是在利用关于英语的其他知识时，例如 **q** 后面通常跟着 **u**，以及 **h** 很可能出现在 **t** 和 **e** 之间）。我们由此得出结论：尽管单表替换密码拥有巨大的密钥空间，但它仍然是不安全的。

It should not be surprising that the mono-alphabetic substitution cipher can be quickly broken, since puzzles based on this cipher are common (and are solved by some people before their morning coffee!). We recommend that you try to decipher the following ciphertext—this should convince you how easy it is to carry out the attack. (Use Figure 1.3.)

单表替换密码能被迅速攻破，这一点不应令人惊讶——因为基于该密码的谜题十分常见（有些人甚至喝早咖啡前就能解出来！）。我们建议你尝试破译下面这段密文——这会让你相信实施这种攻击有多么容易。（利用图 1.3。）

JGRMQOYGHMVBWJWRWQFPWHGFFDQGPFZRBEEBJJZQQOCIBZKLFAFGQVFZFWWEOWOPFGFH
WOLPHLRLOLFDMFGQWBLWBWQOLKFWBYLBLYLFSFLJGRMQBOLWJVFPFWQVHQWFFPQOQVFPQ
OCFPOGFWFJIGFQVHLHLROQVFGWJVFPFOLFHGQVQVFILEOGQILHQFQGIQWVOSFAFGBWQVHQWIJ
VWJVFPFWHGFVIWZZRQGBABHZQOCGFHX

An improved attack on the shift cipher. We can use letter-frequency tables to give an improved attack on the shift cipher. Our previous attack on the shift cipher required decrypting the ciphertext using each possible key, and then checking which key results in a plaintext that "makes sense." A drawback of this approach is that it is somewhat difficult to automate, since it is difficult for a computer to check whether a given plaintext "makes sense." (We do not claim that it would be impossible, as the attack could be automated using a dictionary of valid English words.) More importantly, there may be cases—we will see one later—where the plaintext characters follow the same distribution as English-language text even though the plaintext itself is not valid English, in which case checking for a plaintext that "makes sense" will not work.

对移位密码的一种改进攻击。我们可以利用字母频率表给出对移位密码的一种改进攻击。我们先前对移位密码的攻击需要用每一个可能的密钥去解密密文，然后检查哪个密钥会产生"有意义"的明文。这种做法的一个缺点是它有点难以自动化，因为让计算机检查一段给定的明文是否"有意义"是困难的。（我们并非声称这不可能，因为该攻击可以使用一部合法英文单词的字典来加以自动化。）更重要的是，可能存在这样的情形——我们稍后会看到一个——其中明文字符遵循与英文文本相同的分布，但明文本身并不是合法的英文；在这种情况下，检查明文是否"有意义"就行不通了。

We now describe an attack that does not suffer from these drawbacks. As before, associate the letters of the English alphabet with $0, \dots, 25$. Let p_i , with $0 \leq p_i \leq 1$, denote the frequency of the i th letter in normal English text (i.e., $p_0 = 0.082$ using Figure 1.3). Calculation using Figure 1.3 gives

我们现在描述一种不存在上述缺点的攻击。和之前一样，把英文字母表的字母与 $0, \dots, 25$ 相关联。设 p_i ($0 \leq p_i \leq 1$) 表示正常英文文本中第 i 个字母的频率（即，利用图 1.3, $p_0 = 0.082$ ）。由图 1.3 计算可得

$$\sum_{i=0}^{25} p_i^2 \approx 0.065. \quad (1.1)$$

Now, say we are given some ciphertext and let q_i denote the frequency of the i th letter of the alphabet in this ciphertext; i.e., q_i is simply the number of occurrences of the i th letter of the alphabet in the ciphertext divided by the length of the ciphertext. If the key is k , then p_i should be roughly equal to q_{i+k} for all i because the i th letter is mapped to the $(i+k)$ th letter. (We use $i+k$ instead of the more cumbersome $[i+k \bmod 26]$.) Thus, if we compute

现在，假设给定某段密文，并设 q_i 表示该密文中字母表第 i 个字母的频率；也就是说， q_i 就是密文中字母表第 i 个字母的出现次数除以密文长度。如果密钥为 k ，那么对所有 i ， p_i 应当大致等于 q_{i+k} ，因为第 i 个字母被映射到了第 $(i+k)$ 个字母。（我们用 $i+k$ 来代替更累赘的 $[i+k \bmod 26]$ 。）于是，如果我们计算

$$I_j \stackrel{\text{def}}{=} \sum_{i=0}^{25} p_i \cdot q_{i+j} \quad (1.2)$$

for each value of $j \in \{0, \dots, 25\}$, then we expect to find that $I_k \approx 0.065$ (where k is the actual key), whereas I_j for $j \neq k$ will be different from 0.065. This leads to a key-recovery attack that is easy to automate: compute I_j for all j , and then output the value k for which I_k is closest to 0.065.

对每一个 $j \in \{0, \dots, 25\}$ 的取值都进行计算，那么我们预期会发现 $I_k \approx 0.065$ （其中 k 是真正的密钥），而 $j \neq k$ 时的 I_j 则会偏离 0.065。这就引出了一种易于自动化的密钥恢复攻击：对所有 j 计算 I_j ，然后输出使 I_k 最接近 0.065 的那个 k 值。

The Vigenère (poly-alphabetic shift) cipher. The statistical attack on the mono-alphabetic substitution cipher can be carried out because the key defines a fixed mapping that is applied letter-by-letter to the plaintext. Such an attack could be thwarted by using a poly-alphabetic substitution cipher where the key instead defines a mapping that is applied on blocks of plaintext characters. Here, for example, a key might map the 2-character block *ab* to *DZ* while mapping *ac* to *TY*; note that the plaintext character *a* does not get mapped to a fixed ciphertext character. Poly-alphabetic substitution ciphers "smooth out" the frequency distribution of characters in the ciphertext and make it harder to perform statistical analysis.

维吉尼亚密码（多表移位密码）。对单表替换密码的统计攻击之所以能够实施，是因为密钥定义了一个逐字母地应用于明文的固定映射。这种攻击可以通过使用多表替换密码（poly-alphabetic substitution cipher）来挫败——在多表替换密码中，密钥所定义的映射是应用于明文字符块的。例如，一个密钥可能把 2 字符块 *ab* 映射到 *DZ*，同时把 *ac* 映射到 *TY*；注意明文字符 *a* 并不会被映射到一个固定的密文字符。多表替换密码“抚平”了密文中字符的频率分布，使统计分析更难进行。

The Vigenère cipher, a poly-alphabetic shift cipher that is a special case of the above, can be viewed as applying different instances of the shift cipher to different parts of the plaintext. The key is now viewed as a string of letters; encryption is done by shifting each plaintext character by the amount indicated by the next character of the key, wrapping around in the key when necessary. (This degenerates to the shift cipher if the key has length 1.) For example, encryption of the message *tellhimaboutme* using the key *cafe* would work as follows:

维吉尼亚密码 (Vigenère cipher) 是上述多表替换密码的一个特例，是一种多表移位密码，可以看作是
把移位密码的不同实例应用到明文的不同部分。此时密钥被看作一个字母串；加密时，每个明文字符按
密钥的下一个字符所指示的数值进行移位，必要时在密钥中回绕。（如果密钥长度为 1，这就退化成移位
密码。）例如，使用密钥 cafe 对消息 tellhimaboutme 进行加密，过程如下：

Plaintext:	tellhimaboutme
Key (repeated):	cafecafecafeca
Ciphertext:	VEQPJIREDZXOE

(对应关系：Plaintext 为明文，Key (repeated) 为重复的密钥，Ciphertext 为密文。)

(The key need not be an English word.) This is exactly the same as encrypting the first, fifth, ninth, ... characters with the shift cipher and key c; the second, sixth, tenth, ... characters with key a; the third, seventh, ... characters with f; and the fourth, eighth, ... characters with e. Notice that in the above example l is mapped once to Q and once to P. Furthermore, the ciphertext character E is sometimes obtained from e and sometimes from a. Thus, the character frequencies of the ciphertext are "smoothed out," as desired.

(密钥不一定是英文单词。)这与如下做法完全相同：用移位密码和密钥 c 加密第 1、5、9.....个字符；用密钥 a 加密第 2、6、10.....个字符；用 f 加密第 3、7.....个字符；用 e 加密第 4、8.....个字符。注意在上面的例子中，l 一次被映射到 Q，一次被映射到 P。此外，密文字符 E 有时来自 e，有时来自 a。于是，密文的字符频率便如所愿地被"抚平"了。

If the key is sufficiently long, cracking this cipher appears daunting. Indeed, it had been considered by many to be "unbreakable," and although it was invented in the 16th century, a systematic attack on the scheme was only devised hundreds of years later.

如果密钥足够长，破译这种密码似乎令人望而生畏。事实上，它曾被许多人认为是"不可破译的"，而且尽管它发明于 16 世纪，针对该方案的系统性攻击直到数百年后才被设计出来。

Attacking the Vigenère cipher. A first observation in attacking the Vigenère cipher is that if the length of the key is known then attacking the cipher is relatively easy. Specifically, say the length of the key, also called the period, is t . Write the key k as $k = k_1 \cdots k_t$ where each k_i is a letter of the alphabet. An observed ciphertext $c = c_1 c_2 \cdots$ can be divided into t parts where each part can be viewed as having been encrypted using the shift cipher. Specifically, for all $j \in \{1, \dots, t\}$ the ciphertext characters

攻击维吉尼亚密码。攻击维吉尼亚密码的第一个观察是：如果密钥长度已知，那么攻击该密码就相对容易。具体而言，设密钥的长度（也称为周期）为 t 。把密钥 k 写作 $k = k_1 \cdots k_t$ ，其中每个 k_i 是字母表中的一个字母。一个观察到的密文 $c = c_1 c_2 \cdots$ 可以被分成 t 部分，其中每一部分都可以看作是用移位密码加密的。具体而言，对所有 $j \in \{1, \dots, t\}$ ，密文字符

$$c_j, c_{j+t}, c_{j+2t}, \dots$$

all resulted by shifting the corresponding characters of the plaintext by k_j positions. We refer to the above sequence of characters as the j th stream. All that remains is to determine, for each of the t streams, which of the 26 possible shifts was used. This is not as trivial as in the case of the shift cipher, because it is no longer possible to simply try different shifts in an attempt to determine when decryption of a stream "makes sense." (Recall that a stream does not correspond to consecutive letters in the plaintext.) Furthermore, trying to guess the entire key k at once would require a brute-force search through 26^t different possibilities, which is infeasible for large t . Nevertheless, we can still use letter-frequency analysis to analyze each stream independently.

Namely, for each stream we tabulate the frequency of each ciphertext character and then check which of the 26 possible shifts yields the "right" probability distribution for that stream. Since this can be carried out independently for each stream (i.e., for each character of the key), this attack takes time $26 \cdot t$ rather than time 26^t .

都是通过把明文相应字符移动 k_j 位得到的。我们把上述字符序列称为第 j 个流 (stream)。剩下要做的只是：对这 t 个流中的每一个，确定 26 种可能的移位中哪一种被使用了。这并不像移位密码的情形那样简单，因为现在已无法通过简单地尝试不同移位来确定何时一个流的解密"有意义"了。（回想一下，一个流并不对应明文中连续的字母。）此外，想要一次性猜出整个密钥 k ，需要在 26^t 种可能性中进行穷举搜索，当 t 较大时这是不可行的。尽管如此，我们仍可利用字母频率分析来独立地分析每一个流。也就是说，对每个流，我们统计每个密文字符的频率，然后检查 26 种可能的移位中哪一种对该流产生"正确"的概率分布。由于这件事可以针对每个流（即密钥的每个字符）独立进行，所以该攻击所需时间为 $26 \cdot t$ ，而非 26^t 。

A more principled, easier-to-automate approach is to apply the improved attack on the shift cipher (discussed earlier) to each stream. That attack did not rely on checking for a plaintext that "made sense," but only relied on the underlying frequency distribution of characters in the plaintext.

一种更有原则、更易自动化的方法，是把先前讨论过的对移位密码的改进攻击应用到每一个流上。那种攻击并不依赖于检查明文是否"有意义"，而仅仅依赖于明文字符潜在的频率分布。

Either of the above approaches gives a successful attack when the key length is known. What if the key length is unknown?

当密钥长度已知时，上述两种方法都能给出成功的攻击。那么，如果密钥长度未知呢？

Note first that as long as the maximum length T of the key is not too large, we can simply repeat the above attack T times (once for each possible value $t \in \{1, \dots, T\}$). This leads to at most T different candidate plaintexts, among which the true plaintext will likely be easy to identify. So an unknown key length is not a serious obstacle.

首先注意，只要密钥的最大长度 T 不太大，我们就可以简单地重复上述攻击 T 次（对每个可能的取值 $t \in \{1, \dots, T\}$ 各一次）。这会得到至多 T 个不同的候选明文，其中真正的明文很可能容易识别出来。因此，未知的密钥长度并非严重的障碍。

There are also more efficient ways to determine the key length from an observed ciphertext. One is to use Kasiski's method, published in the mid-19th century. The first step here is to identify repeated patterns of length 2 or 3 in the ciphertext. These are likely the result of certain bigrams or trigrams that appear frequently in the plaintext. For example, consider the common word "the." This word will be mapped to different ciphertext characters, depending on its position in the plaintext. However, if it appears twice in the same relative position, then it will be mapped to the same ciphertext characters. For a sufficiently long plaintext, there is thus a good chance that "the" will be mapped repeatedly to the same ciphertext characters.

也有一些更高效的方法，可以从观察到的密文中确定密钥长度。其一是使用 Kasiski 方法 (Kasiski's method)，发表于 19 世纪中叶。该方法的第一步是识别密文中长度为 2 或 3 的重复模式。这些重复模式很可能是明文中频繁出现的某些二元组 (bigram) 或三元组 (trigram) 造成的。例如，考虑常见单词 "the"。这个单词会依据其在明文中的位置被映射到不同的密文字符。然而，如果它两次出现在相同的相对位置上，那么它就会被映射到相同的密文字符。对于足够长的明文，"the" 就有相当大的概率被反复映射到相同的密文字符。

Consider the following concrete example with the key beads (spaces have been added for clarity):

考虑下面这个用密钥 beads 的具体例子（为清楚起见添加了空格）：

Plaintext: the man and the woman retrieved the letter from the post office
 Key: beadsbeadsbeadsbeadsbeadsbeadsbeadsbeadsbeadsbeadsbeadsb
 Ciphertext: ULE PSO ENG LII WREBR RHLSMEYWE XHH DFXTHJ GVOP LII PRKU SFIADI

The word the is mapped sometimes to ULE, sometimes to LII, and sometimes to XHH. However, it is mapped twice to LII, and in a long enough text it is likely that it would be mapped multiple times to each possibility. Kasiski's observation was that the distance between such repeated appearances (assuming they are not coincidental) is a multiple of the period. (In the above example, the period is 5 and the distance between the two appearances of LII is 30, which is 6 times the period.) Therefore, the greatest common divisor of the distances between repeated sequences (assuming they are not coincidental) will yield the key length t or a multiple thereof.

单词 the 有时被映射到 ULE, 有时被映射到 LII, 有时被映射到 XHH。然而, 它有两次被映射到 LII; 在足够长的文本中, 它很可能被多次映射到每一种可能。Kasiski 的观察是: 此类重复出现 (假定并非巧合) 之间的距离是周期的倍数。(在上面的例子中, 周期为 5, 两次 LII 出现之间的距离为 30, 即周期的 6 倍。) 因此, 各重复序列 (假定并非巧合) 之间距离的最大公约数, 将给出密钥长度 t 或其倍数。

An alternative approach, called the index of coincidence method, is more methodical and hence easier to automate. Recall that if the key length is t , then the ciphertext characters

另一种称为重合指数法 (index of coincidence method) 的方法更为系统, 因而也更易自动化。回想一下, 如果密钥长度为 t , 那么密文字符

$$c_1, c_{1+t}, c_{1+2t}, \dots$$

in the first stream all resulted from encryption using the same shift. This means that the frequencies of the characters in this sequence are expected to be identical to the character frequencies of standard English text in some shifted order. In more detail: let q_i denote the observed frequency of the i th letter in this stream; this is simply the number of occurrences of the i th letter of the alphabet divided by the total number of letters in the stream. If the shift used here is j (i.e., if the first character k_1 of the key is equal to j), then for all i we expect $q_{i+j} \approx p_i$, where p_i is the frequency of the i th letter of the alphabet in standard English text. (Once again, we use q_{i+j} in place of $q_{[i+j \bmod 26]}$.) But this means that the sequence $q_0, \dots, q_{25}$ is just the sequence $p_0, \dots, p_{25}$ shifted j places. As a consequence (cf. Equation (1.1)):

在第一个流中, 都是由使用同一个移位进行加密得到的。这意味着该序列中字符的频率, 预期会与标准英文文本的字符频率在某种移位顺序下完全相同。更具体地说: 设 q_i 表示该流中第 i 个字母的观测频率; 它就是字母表第 i 个字母的出现次数除以该流中字母的总数。如果此处使用的移位是 j (即如果密钥的第一个字符 k_1 等于 j), 那么对所有 i , 我们预期 $q_{i+j} \approx p_i$, 其中 p_i 是字母表第 i 个字母在标准英文文本中的频率。(我们再一次用 q_{i+j} 代替 $q_{[i+j \bmod 26]}$ 。) 但这就意味着序列 $q_0, \dots, q_{25}$ 正是序列 $p_0, \dots, p_{25}$ 移位 j 位后的结果。由此可得 (参见等式 (1.1)) :

$$\sum_{i=0}^{25} q_i^2 \approx \sum_{i=0}^{25} p_i^2 \approx 0.065.$$

This leads to a nice way to determine the key length t . For $\tau = 1, 2, \dots, T$, look at the sequence of ciphertext characters $c_1, c_{1+\tau}, c_{1+2\tau}, \dots$ and tabulate $q_0, \dots, q_{25}$ for this sequence. Then compute

这就引出了一种确定密钥长度 t 的巧妙方法。对 $\tau = 1, 2, \dots, T$, 考察密文字符序列 $c_1, c_{1+\tau}, c_{1+2\tau}, \dots$, 并为该序列统计 $q_0, \dots, q_{25}$ 。然后计算

$$S_\tau \stackrel{\text{def}}{=} \sum_{i=0}^{25} q_i^2. \quad (1.3)$$

When $\tau = t$ we expect $S_\tau \approx 0.065$, as discussed above. On the other hand, if τ is not a multiple of t we expect that all characters will occur with roughly equal probability in the sequence $c_1, c_{1+\tau}, c_{1+2\tau}, \dots$, and so we expect $q_i \approx 1/26$ for all i . In this case we will obtain

如上所述, 当 $\tau = t$ 时, 我们预期 $S_\tau \approx 0.065$ 。另一方面, 如果 τ 不是 t 的倍数, 我们预期在序列 $c_1, c_{1+\tau}, c_{1+2\tau}, \dots$ 中所有字符会以大致相等的概率出现, 因此对所有 i 预期 $q_i \approx 1/26$ 。在这种情况下, 我们将得到

$$S_\tau \approx \sum_{i=0}^{25} \left(\frac{1}{26} \right)^2 \approx 0.038.$$

The smallest value of τ for which $S_\tau \approx 0.065$ is thus likely the key length. One can further validate a guess τ by carrying out a similar calculation using the second stream $c_2, c_{2+\tau}, c_{2+2\tau}, \dots$, etc.

因此, 使 $S_\tau \approx 0.065$ 的最小的 τ , 很可能就是密钥长度。人们还可以用第二个流 $c_2, c_{2+\tau}, c_{2+2\tau}, \dots$ 等进行类似的计算, 以进一步验证对 τ 的猜测。

Ciphertext length and cryptanalytic attacks. The above attacks on the Vigenère cipher require a longer ciphertext than the attacks on previous schemes. For example, the index of coincidence method requires c_1, c_{1+t}, c_{1+2t} (where t is the actual key length) to be sufficiently long in order to ensure that the observed frequencies are close to what is expected; the ciphertext itself must then be roughly t times larger. Similarly, the attack we showed on the mono-alphabetic substitution cipher requires a longer ciphertext than the attack on the shift cipher (which can work for encryptions of even a single word). This illustrates that a longer key can, in general, require the cryptanalyst to obtain more ciphertext in order to carry out an attack. (Indeed, the Vigenère cipher can be shown to be secure if the key is as long as what is being encrypted. We will see a related phenomenon in the next chapter.)

密文长度与密码分析攻击。上述对维吉尼亚密码的攻击, 比针对先前方案的攻击需要更长的密文。例如, 重合指数法要求 c_1, c_{1+t}, c_{1+2t} (其中 t 是真正的密钥长度) 足够长, 才能保证观测到的频率接近预期值; 于是密文本身必须大约长 t 倍。类似地, 我们所展示的对单表替换密码的攻击, 比针对移位密码的攻击 (后者甚至对单个单词的加密也能奏效) 需要更长的密文。这表明: 一般而言, 更长的密钥可能要求密码分析者获取更多的密文才能实施攻击。(事实上可以证明, 如果密钥与被加密的内容一样长, 维吉尼亚密码就是安全的。我们将在下一章看到相关的现象。)

Conclusions. We have presented only a few historical ciphers. Beyond their historical interest, our aim in presenting them was to illustrate some important lessons. Perhaps the most important is that designing secure ciphers is hard. The Vigenère cipher remained unbroken for a long time. Far more complex schemes have also been used. But a complex scheme is not necessarily secure, and all historical schemes have been broken.

小结。我们只介绍了少数几种历史密码。除了其历史意义之外, 我们介绍它们的目的在于阐明一些重要的经验。也许最重要的一条是: 设计安全的密码很难。维吉尼亚密码在很长一段时间里未被破译。人们也曾使用过远为复杂的方案。但是, 复杂的方案未必安全, 而所有这些历史密码都已被破译。

1.4 Principles of Modern Cryptography 现代密码学原则

As should be clear from the previous section, cryptography was historically more of an art than a science. Schemes were designed in a heuristic manner and evaluated based on their perceived complexity or cleverness. A scheme would be analyzed to see if any attacks could be found; if so, the scheme would be "patched" to thwart that attack, and the process repeated. Although there may have been agreement that some schemes were not secure (as evidenced by an especially

damaging attack), there was no agreed-upon notion of what requirements a "secure" scheme should satisfy, and no way to give evidence that any specific scheme was secure.

由上一节应当清楚，密码学在历史上与其说是一门科学，不如说是一门艺术。方案以启发式的方式设计，并根据人们所感知到的复杂性或巧妙程度来评估。一个方案会被分析以查看是否能找到任何攻击；如果找到了，该方案就会被“打补丁”以挫败该攻击，然后重复这一过程。尽管人们可能对某些方案的不安全性达成共识（其证据是某种特别具破坏性的攻击），但并不存在一个公认的、关于“安全”方案应当满足何种要求的概念，也没有办法给出证据表明某个具体方案是安全的。

Over the past several decades, cryptography has developed into more of a science. Schemes are now developed and analyzed in a more systematic manner, with the ultimate goal being to give a rigorous proof that a given construction is secure. In order to articulate such proofs, we first need formal definitions that pin down exactly what "secure" means; such definitions are useful and interesting in their own right. As it turns out, most cryptographic proofs rely on currently unproven assumptions about the algorithmic hardness of certain mathematical problems; any such assumptions must be made explicit and be stated precisely. An emphasis on definitions, assumptions, and proofs distinguishes modern cryptography from classical cryptography; we now discuss these three principles in greater detail.

在过去几十年里，密码学已经发展得更像一门科学。如今，方案的开发和分析更加系统化，其终极目标是给出一个严谨的证明，表明某个给定构造是安全的。为了陈述这样的证明，我们首先需要形式化的定义，精确地界定“安全”的含义；这些定义本身就很有用，也很有趣。事实证明，大多数密码学证明都依赖于关于某些数学问题算法难度的、目前尚未获证的假设；任何此类假设都必须被明确地、精确地陈述出来。对定义、假设和证明的强调，正是现代密码学区别于经典密码学之处；下面我们更详细地讨论这三条原则。

1.4.1 Principle 1 – Formal Definitions 原则一：形式化定义

One of the key contributions of modern cryptography has been the recognition that formal definitions of security are essential for the proper design, study, evaluation, and usage of cryptographic primitives. Put bluntly:

现代密码学的一个关键贡献，是认识到安全性的形式化定义对于密码学原语的设计、研究、评估和使用都是不可或缺的。直白地说：

If you don't understand what you want to achieve, how can you possibly know when (or if) you have achieved it?

如果你不明白自己想要达成什么，又怎么可能知道你何时（或是否）已经达成了它？

Formal definitions provide such understanding by giving a clear description of what threats are in scope and what security guarantees are desired. As such, definitions can help guide the design of cryptographic schemes. Indeed, it is much better to formalize what is required before the design process begins, rather than to come up with a definition post facto once the design is complete. The latter approach risks having the design phase end when the designer's patience is exhausted (rather than when the goal has been met), or may result in a construction achieving more than is needed at the expense of efficiency.

形式化定义通过清晰地描述哪些威胁在范围内、期望获得何种安全保证，从而提供了这样的理解。正因如此，定义有助于指导密码方案的设计。事实上，在设计过程开始之前就把所需的要求形式化，远比在设计完成之后再“事后”给出一个定义为好。后一种做法有风险：设计阶段可能因设计者的耐心耗尽而告终（而不是因为目标已达成），或者可能得到一个超出所需、却牺牲了效率的构造。

Definitions also offer a way to evaluate and analyze constructions. With a definition in place, one can study a proposed scheme to see if it achieves the desired guarantees; in some cases, one can even prove a given construction secure (see Section 1.4.3) by showing that it meets the definition. On the flip side, definitions can be used to conclusively show that a given scheme is not secure, insofar as the scheme does not satisfy the definition. In particular, observe that the attacks in the previous section do not conclusively demonstrate that any of the schemes shown there is "insecure." For example, the attack on the Vigenère cipher assumed that sufficiently long English text was being encrypted, but perhaps the Vigenère cipher is "secure" if short English text, or compressed text (which will have roughly uniform letter frequencies), is encrypted? It is hard to say without a formal definition in place.

定义也提供了一种评估和分析构造的方式。有了定义之后，人们就可以研究某个被提出的方案，看它是否达到了所期望的保证；在某些情形下，甚至可以通过证明某个构造满足该定义，来证明它是安全的（见 1.4.3 节）。反过来，定义也可以用来确凿地表明某个给定方案是不安全的——只要该方案不满足定义。特别地，请注意：上一节中的攻击并没有确凿地证明那里展示的任何一个方案是“不安全的”。例如，对维吉尼亚密码的攻击假定被加密的是足够长的英文文本，但倘若被加密的是简短的英文文本，或者是经过压缩的文本（其字母频率大致均匀），那么维吉尼亚密码也许是“安全”的？在没有形式化定义的情况下，这很难说。

Definitions enable a meaningful comparison of schemes. As we will see, there can be multiple (valid) ways to define security; the "right" one depends on the context in which a scheme is used. A scheme satisfying a weaker definition may be more efficient than another scheme satisfying a stronger definition; with precise definitions we can properly evaluate the trade-offs between the two schemes. Along the same lines, definitions enable secure usage of schemes. Consider deciding which encryption scheme to use for some larger application. A sound way to approach the problem is to first understand what notion of security is required for that application, and then find an encryption scheme satisfying that notion. A side benefit of this approach is modularity: a designer can "swap out" one encryption scheme and replace it with another (that also satisfies the necessary definition of security) without having to worry about affecting security of the overall application.

定义使得方案之间能够进行有意义的比较。正如我们将看到的，定义安全性的（有效）方式可以有多种；“正确”的定义取决于方案使用的语境。满足较弱定义的方案，可能比满足较强定义的方案更高效；有了精确的定义，我们就能恰当地评估两种方案之间的权衡。同理，定义也使得方案能够被安全地使用。考虑为某个更大的应用决定使用哪一种加密方案。处理该问题的一种稳妥方式是：先理解该应用需要何种安全概念，然后寻找一个满足该概念的加密方案。这种做法的一个附带好处是模块化：设计者可以“替换掉”一个加密方案，换上另一个（同样满足必要的安全性定义的）方案，而无需担心影响整个应用的安全性。

Writing a formal definition forces one to think about what is essential to the problem at hand and what properties are extraneous. Going through the process often reveals subtleties of the problem that were not obvious at first glance. We illustrate this next for the case of encryption.

撰写形式化定义，会迫使人们思考什么对手头的问题是本质的、什么属性是无关的。经历这一过程，往往会暴露出问题中那些乍看并不明显的微妙之处。下面我们就加密的情形加以说明。

An example: secure encryption. A common mistake is to think that formal definitions are not needed, or are trivial to come up with, because "everyone has an intuitive idea of what security means." This is not the case. As an example, we consider the case of encryption. (The reader may want to pause here to think about how they would formally define what it means for an encryption scheme to be secure.) Although we postpone a formal definition of secure encryption to subsequent chapters, we describe here informally what such a definition should capture.

一个例子：安全的加密。一个常见的错误是认为形式化定义并不需要、或者很容易给出，因为“每个人都对安全的含义有一个直观的概念”。事实并非如此。作为一个例子，我们考虑加密的情形。（读者在此不妨停下来想一想，自己会如何形式化地定义一个加密方案“安全”的含义。）尽管我们把安全加密的形式化定义推迟到后续章节，但在此我们先非正式地描述一下这样一个定义应当刻画什么。

In general, a security definition has two components: a security guarantee (or, from the attacker's point of view, what constitutes a successful attack) and a threat model. The security guarantee defines what the scheme is intended to prevent the attacker from doing, while the threat model describes the power of the adversary, i.e., what actions the attacker is assumed able to carry out.

一般而言，一个安全性定义包含两个组成部分：安全性保证（或者，从攻击者的角度看，什么构成一次成功的攻击）以及威胁模型。安全性保证定义了方案意图阻止攻击者做什么，而威胁模型则描述了敌手的能力，即假定攻击者能够执行哪些动作。

Let's start with the first of these. What should a secure encryption scheme guarantee? Here are some thoughts:

让我们先从这两者中的第一个开始。一个安全的加密方案应当保证什么？以下是一些思考：

- It should be impossible for an attacker to recover the key. We have previously observed that if an attacker can determine the key shared by two parties using some scheme, then that scheme cannot be secure. However, it is easy to come up with schemes for which key recovery is impossible, yet the scheme is blatantly insecure. Consider, e.g., the scheme where $\text{Enc}_k(m) = m$. The ciphertext leaks no information about the key (and so the key cannot be recovered if it is long enough) yet the message is sent in the clear! We thus see that inability to recover the key is necessary but not sufficient for security. This makes sense: the aim of encryption is to protect the message; secrecy of the key is a means for achieving this goal, but is not itself the objective.

攻击者应当无法恢复出密钥。我们先前已经观察到，如果攻击者能用某种方案确定两方共享的密钥，那么该方案就不可能是安全的。然而，很容易举出这样的方案：对它而言密钥恢复是不可能的，但该方案却公然不安全。例如，考虑 $\text{Enc}_k(m) = m$ 这一方案。其密文不会泄露关于密钥的任何信息（因此如果密钥足够长，密钥就无法被恢复），然而消息却是明文发送的！由此可见，无法恢复密钥对安全性而言是必要但不充分的。这是合乎情理的：加密的目的是保护消息；密钥的保密只是实现这一目标的手段，其本身并不是目标。

- It should be impossible for an attacker to recover the plaintext from the ciphertext. This definition is better, but is still far from satisfactory. In particular, this definition would consider an encryption scheme secure if its ciphertexts revealed 90% of the plaintext, as long as 10% of the plaintext remained hard to figure out. This is clearly unacceptable in most common applications of encryption; for example, when encrypting a salary database, we would be justifiably upset if 90% of employees' salaries were revealed!

攻击者应当无法从密文恢复出明文。这个定义要好一些，但仍远不能令人满意。特别地，按照这个定义，如果一个加密方案的密文泄露了 90% 的明文，只要剩下 10% 的明文仍难以推断，它就会被视为是安全的。这在大多数常见的加密应用中显然是不可接受的；例如，在加密一个薪资数据库时，如果 90% 员工的薪资被泄露，我们有理由感到愤怒！

- It should be impossible for an attacker to recover any character of the plaintext from the ciphertext. This looks like a good definition, yet is still not sufficient. Going back to the example of encrypting a salary database, we would not consider an encryption scheme secure if it reveals whether an employee's salary is more than or less than \$100,000, even if it does not reveal any particular digit of that employee's salary. Similarly, we would not want an encryption scheme to reveal whether one particular employee makes more than another. 攻击者应当无法从密文恢复出明文的任何一个字符。这个定义看起来不错，但仍然不够。回到加密薪资数据库的例子：如果一个加密方案泄露了某位员工的薪资是高于还是低于 \$100,000，即便它没

有泄露该员工薪资的任何一个具体数字，我们也不会认为它是安全的。类似地，我们也不希望一个加密方案泄露某位特定员工是否比另一位挣得多。

Another issue is how to formalize what it means for an adversary to "recover a character of the plaintext." What if an attacker correctly guesses, through sheer luck or external information, that the least significant digit of someone's salary is 0? Clearly that should not render an encryption scheme insecure, and so any viable definition must somehow rule out such behavior from qualifying as a successful attack.

另一个问题是，如何形式化"敌手恢复出明文的一个字符"的含义。如果攻击者纯粹凭运气或外部信息，正确猜出某人薪资的最低位数字是 0 呢？显然，这不应使一个加密方案变得不安全；因此，任何可行的定义都必须以某种方式把这种行为排除在"成功攻击"之外。

- The "right" answer: regardless of any information an attacker already has, a ciphertext should leak no additional information about the underlying plaintext. This informal definition captures all the concerns outlined above. Note in particular that it does not try to define what information about the plaintext is "meaningful"; it simply requires that no information be leaked. This is important, as it means that a secure encryption scheme is suitable for all potential applications in which secrecy is required.

"正确的"答案：无论攻击者已经掌握了什么信息，一段密文都不应泄露关于其底层明文的任何额外信息。这一定义（非正式地）涵盖了上述所有顾虑。特别要注意，它并不试图定义明文的哪些信息是"有意义的"；它只要求不泄露任何信息。这一点很重要，因为它意味着一个安全的加密方案适用于所有需要保密的潜在应用。

What is missing here is a precise, mathematical formulation of the definition. How should we capture an attacker's prior knowledge about the plaintext? And what does it mean to (not) leak information? We will return to these questions in the next two chapters; see especially Definitions 2.3 and 3.12.

这里所缺少的，是该定义的一个精确的数学表述。我们应当如何刻画攻击者对明文的先验知识？又如何理解（不）泄露信息的含义？我们将在接下来的两章中回到这些问题；特别参见定义 2.3 和 3.12。

Now that we have fixed a security goal, it remains to specify a threat model. This specifies what "power" the attacker is assumed to have, but does not place any restrictions on the adversary's strategy. This is an important distinction: we specify what we assume about the adversary's abilities, but we do not assume anything about how it uses those abilities. It is impossible to foresee what strategies might be used in an attack, and history has proven that attempts to do so are doomed to failure.

既然我们已经确定了安全目标，接下来就要指定威胁模型。威胁模型规定了假定攻击者拥有何种"能力"，但并不对敌手的策略施加任何限制。这是一个重要的区分：我们规定的是关于敌手能力的假设，而对它如何使用这些能力则不作任何假设。攻击中可能用到什么策略是无法预见的，历史也已证明，试图这样做的努力注定会失败。

There are several plausible options for the threat model in the context of encryption; standard ones, in order of increasing power of the attacker, are:

在加密的语境下，威胁模型有若干种合理的选择；以下是标准的几种，按攻击者能力由弱到强排列：

- Ciphertext-only attack: This is the most basic attack, where the adversary just observes a ciphertext (or multiple ciphertexts) and attempts to determine information about the underlying plaintext (or plaintexts). This is the threat model we have been implicitly assuming when discussing classical encryption schemes in the previous section.

唯密文攻击（ciphertext-only attack）：这是最基本的攻击，敌手只是观察一段（或多段）密文，并试图确定底层明文（或多段明文）的信息。这正是我们在上一节讨论经典加密方案时一直在暗中假定的威胁模型。

- Known-plaintext attack: Here, the adversary is able to learn one or more plaintext/ciphertext pairs generated using some key. The aim of the adversary is then to deduce information about the underlying plaintext of some other ciphertext produced using the same key.
已知明文攻击 (known-plaintext attack) : 在这里, 敌手能够获知用某个密钥生成的一个或多个明文/密文对。敌手的目标是据此推断出用同一密钥产生的另一段密文底层明文的信息。

All the classical encryption schemes we have seen are trivial to break using a known-plaintext attack; we leave a demonstration as an exercise.

我们所见过的所有经典加密方案, 用已知明文攻击来破译都轻而易举; 我们把它作为一个练习留给读者。

- Chosen-plaintext attack: In this attack, the adversary can obtain plaintext/ciphertext pairs, as above, for plaintexts of its choice.

选择明文攻击 (chosen-plaintext attack) : 在这种攻击中, 如同上述, 敌手可以为其所选的明文获取明文/密文对。

- Chosen-ciphertext attack: The final type of attack is one where the adversary is additionally able to obtain (some information about) the decryption of ciphertexts of its choice, e.g., whether the decryption of some ciphertext chosen by the attacker yields a valid English message. The adversary's aim, once again, is to learn information about the underlying plaintext of some other ciphertext (whose decryption the adversary is unable to obtain directly) generated using the same key.

选择密文攻击 (chosen-ciphertext attack) : 最后一种攻击中, 敌手还能额外地获取其选定密文的解密 (的某些信息), 例如攻击者选定的某段密文的解密是否为一条合法的英文消息。敌手的目标同样是要获知用同一密钥生成的另一段密文 (敌手无法直接获得其解密) 底层明文的信息。

Although the threat models are listed in order of increasing strength, none of them is inherently better than any other; the right one to use depends on the environment in which an encryption scheme is deployed.

尽管上述威胁模型是按强度由弱到强列出的, 但没有哪一种天生优于其他任何一种; 正确的选择取决于加密方案部署的环境。

The first two types of attack are the easiest to carry out. In a ciphertext-only attack, the only thing the adversary needs to do is eavesdrop on the communication channel over which encrypted messages are sent. In a known-plaintext attack it is assumed the adversary also obtains ciphertexts corresponding to known plaintexts. This is often easy to accomplish because not all encrypted messages are secret, at least not indefinitely. As a trivial example, two parties may always encrypt a "hello" message whenever they begin communicating. As a more complex example, encryption may be used to keep quarterly-earnings reports secret until their release date; in this case, anyone eavesdropping on the ciphertext will later obtain the corresponding plaintext.

前两种攻击最容易实施。在唯密文攻击中, 敌手唯一需要做的, 就是对发送加密消息的通信信道进行窃听。在已知明文攻击中, 假定敌手还能获得与已知明文相对应的密文。这往往很容易做到, 因为并非所有加密消息都是保密的——至少不会永远保密。举个简单的例子, 双方在每次开始通信时可能总是加密一条"hello"消息。举个更复杂的例子, 加密可能被用来使季度盈利报告在发布日之前保密; 在这种情况下, 任何窃听该密文的人, 之后都能获得相应的明文。

In the latter two attacks the adversary is assumed to be able to obtain encryptions and/or decryptions of plaintexts/ciphertexts of its choice. This may at first seem strange, and we defer a more detailed discussion of these attacks, and their practicality, to Section 3.4.2 (for chosen-plaintext attacks) and Section 5.1 (for chosen-ciphertext attacks).

在后两种攻击中，假定敌手能够获得其选定的明文/密文的加密和/或解密。这乍看可能有些奇怪，我们把这些攻击及其实用性的更详细讨论推迟到 3.4.2 节（针对选择明文攻击）和 5.1 节（针对选择密文攻击）。

1.4.2 Principle 2 – Precise Assumptions 原则二：精确假设

Most modern cryptographic constructions cannot be proven secure unconditionally; such proofs would require resolving questions in the theory of computational complexity that seem far from being answered today.⁴ The result of this unfortunate state of affairs is that proofs of security typically rely on assumptions. Modern cryptography requires any such assumptions to be made explicit and mathematically precise. At the most basic level, this is because proofs of security require this. But there are other reasons as well:

大多数现代密码学构造都无法被无条件地证明安全；这样的证明需要解决计算复杂性理论中一些今天看来远未解决的问题。⁴ 这种不如人意的状况所带来的结果是，安全性证明通常依赖于假设。现代密码学要求任何此类假设都必须被明确而精确地陈述。最基本地，这是因为安全性证明本身需要如此。但还有其他一些理由：

1. Validation of assumptions: By their very nature, assumptions are statements that are not proven but are instead conjectured to be true. In order to strengthen our belief in some assumption, it is necessary to study it: The more the assumption is examined and tested without being refuted, the more confident we are that the assumption is true. Furthermore, study of an assumption can provide evidence of its validity by showing that it is implied by some other assumption that is also widely believed.

对假设的检验：就其本质而言，假设是未被证明、而是被推测为真的陈述。为了增强我们对某个假设的信心，必须对它进行研究：该假设被审查和检验而未被驳倒的次数越多，我们就越确信它为真。此外，对假设的研究还能为其有效性提供证据，方法是证明它由另一个同样被广泛相信的假设所蕴含。

If the assumption being relied upon is not precisely stated, it cannot be effectively studied and (potentially) refuted. Thus, a precondition to increasing our confidence in an assumption is having a precise statement of what exactly is being assumed.

如果所依赖的假设没有被精确陈述，它就无法被有效地研究以及（可能地）驳倒。因此，增强我们对某个假设信心的一个前提，是拥有一个关于“究竟假设了什么”的精确陈述。

2. Comparison of assumptions: Often in cryptography we are presented with two schemes that can both be proven to satisfy some definition, each based on a different assumption.

Assuming all else is equal, which scheme should be preferred? If the assumption on which the first scheme is based is weaker than the assumption on which the second scheme is based (i.e., if the second assumption implies the first), then the first scheme is preferable since it may turn out that the second assumption is false while the first assumption is true. If the assumptions used by the two schemes are not comparable, then the general rule is to prefer the scheme that is based on the better-studied assumption in which there is presumably greater confidence.

假设的比较：在密码学中，我们常常会遇到两个方案，它们都能被证明满足某个定义，但各自基于不同的假设。假定其他条件都相同，应优先选择哪个方案？如果第一个方案所基于的假设弱于第二个方案所基于的假设（即第二个假设蕴含第一个），那么第一个方案更可取，因为有可能第二个假设为假而第一个假设为真。如果两个方案所用的假设无法比较，那么一般规则是优先选择基于研究更充分、因而大概也更有信心的假设的那个方案。

3. Understanding the necessary assumptions: An encryption scheme may be based on some underlying building block. If some weaknesses are later found in the building block, how can we tell whether the encryption scheme is still secure? If the underlying assumptions regarding the building block are made clear as part of proving security of the scheme, then we need only check whether the required assumptions are affected by the new weaknesses that were found.

理解必需的假设：一个加密方案可能建立在某个底层构件之上。如果后来在该构件中发现了某些弱点，我们如何判断这个加密方案是否仍然安全？如果在证明方案安全性时，关于该构件的底层假设已被阐明，那么我们只需检查所要求的假设是否受到新发现的弱点的影响。

A question that sometimes arises is: rather than prove a scheme secure based on some other assumption, why not simply assume that the scheme itself is secure? In some cases—e.g., when the definition is simple and a scheme has successfully resisted attack for many years—this may be an acceptable approach. But this approach is not preferred, and is downright dangerous when a new construction is being introduced. The reasons above help explain why. First, an assumption that has been studied for several years is preferable to a new, arbitrary assumption that is introduced along with a new construction. Second, there is a general preference for "simpler" assumptions—i.e., an assumption about the hardness of a clean mathematical problem vs. an assumption that a complex scheme satisfies an elaborate security definition—since simpler assumptions are in general easier to understand and study. Another advantage of relying on "lower-level" assumptions (rather than just assuming a scheme is secure) is that these low-level assumptions can typically be used in other constructions. Finally, low-level assumptions enable modularity. Consider an encryption scheme whose security relies on some assumed property of one of its building blocks. If the underlying building block turns out not to satisfy the stated assumption, the encryption scheme can be instantiated using a different component that satisfies the necessary requirements.

有时会出现这样一个问题：与其基于某个其他假设来证明一个方案安全，为什么不干脆假设该方案本身就是安全的？在某些情况下——例如，当定义很简单、且某个方案已成功抵御攻击多年——这可能是一种可接受的做法。但这种做法并不受推崇，而在引入一个新构造时则相当危险。上面的理由有助于解释其中原因。第一，一个已被研究了数年的假设，要比随某个新构造一同引入的、新的、任意的假设更可取。第二，人们普遍偏好“更简单”的假设——即关于一个干净数学问题难度的假设，而非关于一个复杂方案满足某个详尽安全性定义的假设——因为更简单的假设通常更易于理解和研究。依赖“更底层”假设（而不是仅仅假设一个方案是安全的）的另一个好处是，这些底层假设通常还能用于其他构造。最后，底层假设使得模块化成为可能。考虑一个加密方案，其安全性依赖于其某个构件的某种假定性质。如果该底层构件最终并不满足所陈述的假设，那么该加密方案就可以用一个满足必要要求的不同组件来实例化。

1.4.3 Principle 3 – Proofs of Security 原则三：安全性证明

The two principles just described allow us to achieve our goal of providing rigorous proof that a construction satisfies a given definition under certain assumptions. Such proofs are especially important in the context of cryptography where there is an attacker who is actively trying to "break" some scheme. Proofs of security give an iron-clad guarantee—relative to the definition and assumptions—that no attacker will succeed; this is much better than taking an unprincipled or heuristic approach to the problem. Without a proof that no adversary with the specified resources can break some scheme, we are left only with our intuition that this is the case. Experience has shown that intuition in cryptography and computer security is disastrous. There are countless examples of unproven schemes that were broken, sometimes immediately and sometimes years after being developed.

上述两条原则使我们能够达成目标：在特定假设下，提供一个构造满足某个给定定义的严谨证明。这样的证明在密码学的语境下尤为重要，因为这里总有一个积极试图“攻破”某个方案的攻击者。安全性证明给出了一个铁一般的保证——相对于定义和假设而言——没有任何攻击者能够成功；这远胜于以无原则或启发式的方式来处理问题。如果没有“任何拥有规定资源的敌手都无法攻破某个方案”的证明，我们就只剩下“情况确实如此”的直觉。经验表明，在密码学和计算机安全领域，直觉是灾难性的。有无数未获证明的方案被攻破的例子，有时是立即被攻破，有时是在提出多年之后。

Summary: Rigorous vs. Heuristic Approaches to Security 小结：严谨方法与启发式方法

Reliance on definitions, assumptions, and proofs constitutes a rigorous approach to cryptography that is distinct from the informal approach of classical cryptography. Unfortunately, unprincipled, "off-the-cuff" solutions are still designed and deployed by those wishing to obtain a quick solution to a problem, or by those who are simply unknowledgeable. We hope this book will contribute to an awareness of the rigorous approach and its importance in developing provably secure schemes.

对定义、假设和证明的依赖，构成了一种严谨的密码学研究方法，它有别于经典密码学那种非正式的方法。遗憾的是，那些希望快速获得问题解决方案的人，或者那些仅仅是缺乏相关知识的人，仍在设计和部署毫无原则的、“临时拍脑袋”式的方案。我们希望本书能够有助于人们认识到这种严谨方法及其在开发可证明安全方案中的重要性。

1.4.4 Provable Security and Real-World Security 可证明安全与现实世界安全

Much of modern cryptography now rests on sound mathematical foundations. But this does not mean that the field is no longer partly an art as well. The rigorous approach leaves room for creativity in developing definitions suited to contemporary applications and environments, in proposing new mathematical assumptions and designing new primitives, and in constructing novel schemes and proving them secure. There will also always be the art of attacking deployed cryptosystems, even when they are proven secure. We expand on this point next.

如今，现代密码学的很大一部分已经建立在可靠的数学基础之上。但这并不意味着该领域不再在一定程度上也是一门艺术。严谨的方法为以下方面的创造力留有余地：开发适合当代应用与环境的定义，提出新的数学假设并设计新的原语，以及构造新颖的方案并证明其安全。此外，攻击已部署的密码系统也将始终是一门艺术，即便这些系统已被证明是安全的。我们下面展开谈谈这一点。

The approach taken by modern cryptography has revolutionized the field, and helps provide confidence in the security of cryptographic schemes deployed in the real world. But it is important not to overstate what a proof of security implies. A proof of security is always relative to the definition being considered and the assumption(s) being used. If the security guarantee does not match what is needed, or the threat model does not capture the adversary's true abilities, then the proof may be irrelevant. Similarly, if the assumption that is relied upon turns out to be false, then the proof of security is meaningless.

现代密码学所采取的方法已经使该领域发生了革命性变化，并有助于为现实世界中部署的密码方案的安全性提供信心。但重要的是，不要夸大一个安全性证明所意味的东西。安全性证明总是相对于所考虑的定义和所使用的假设而言的。如果安全性保证与所需的不匹配，或者威胁模型没有刻画敌手的真实能力，那么该证明可能就毫无意义。类似地，如果所依赖的假设最终为假，那么该安全性证明就毫无意义。

The take-away point is that provable security of a scheme does not necessarily imply security of that scheme in the real world.⁵ While some have viewed this as a drawback of provable security, we view this optimistically as illustrating the strength of the approach. To attack a provably secure scheme in the real world, the attacker is forced to focus attention on the definition (i.e., to explore how the idealized definition differs from the real-world requirements) or the underlying assumptions (i.e., to see whether they hold). In turn, it is the job of cryptographers to continually refine their definitions to more closely match the real world, and to investigate their assumptions to test their validity. Provable security does not end the age-old battle between attacker and defender, but it does provide a framework that helps shift the odds in the defender's favor.

这里的关键结论是：一个方案的可证明安全，并不一定意味着该方案在现实世界中就是安全的。⁵ 尽管一些人把这视为可证明安全的一个缺陷，我们却乐观地把它看作是这一方法之强大的一种体现。要在现实世界中攻击一个可证明安全的方案，攻击者不得不把注意力集中到定义上（即探究理想化的定义与现实需求之间有何差异）或底层假设上（即看看它们是否成立）。相应地，密码学家的职责则是不断细化其定义以更贴近现实世界，并研究其假设以检验其有效性。可证明安全并没有终结攻击者与防御者之间由来已久的较量，但它确实提供了一个有助于把胜算倾向防御者一方的框架。

References and Additional Reading 参考文献与延伸阅读

In this chapter, we have studied just a few of the known historical ciphers. There are many others of both historical and mathematical interest, and we refer the reader to textbooks by Stinson [195] or Trappe and Washington [196] for further details. The important role cryptography has played throughout history is a fascinating subject covered in books by Kahn [106] and Singh [188].

在本章中，我们只研究了已知历史密码中的少数几种。还有许多其他在历史和数学上都颇具趣味的历史密码，我们建议读者参阅 Stinson [195] 或 Trappe 与 Washington [196] 的教科书以了解详情。密码学在整部历史中所扮演的重要角色是一个引人入胜的主题，Kahn [106] 和 Singh [188] 的著作对此有所介绍。

Shannon [177] was the first to pursue a rigorous approach to cryptography based on precise definitions and mathematical proofs; we explore his work in the next chapter.

Shannon [177] 是第一个基于精确定义和数学证明来从事严谨密码学研究的人；我们在下一章探讨他的工作。

Exercises 习题

1.1 Decrypt the ciphertext provided at the end of the section on mono-alphabetic substitution ciphers.

解密在单表替换密码一节末尾给出的那段密文。

1.2 Provide a formal definition of the Gen, Enc, and Dec algorithms for the mono-alphabetic substitution cipher.

给出单表替换密码的 Gen、Enc 和 Dec 算法的形式化定义。

1.3 Provide a formal definition of the Gen, Enc, and Dec algorithms for the Vigenère cipher. (Note: there are several plausible choices for Gen; choose one.)

给出维吉尼亚密码的 Gen、Enc 和 Dec 算法的形式化定义。（注：Gen 有几种合理的选择；任选其一。）

1.4 Say you are given a ciphertext that corresponds to English-language text that was encrypted using either the shift cipher or the Vigenère cipher with period greater than 1. How could you tell which was the case?

假设给定你一段密文，它对应于用移位密码、或周期大于 1 的维吉尼亚密码加密的英文文本。你如何判断究竟是哪一种情况？

1.5 Implement the attacks described in this chapter for the shift cipher and the Vigenère cipher.

实现本章所描述的、针对移位密码和维吉尼亚密码的攻击。

1.6 The shift and Vigenère ciphers can also be defined on the 256-character alphabet consisting of all possible bytes (8-bit strings), and using XOR instead of modular addition.

移位密码和维吉尼亚密码也可以定义在由所有可能的字节（8 比特串）构成的 256 字符字母表上，并用 XOR 代替模加。

(a) Provide a formal definition of both schemes in this case.

(a) 给出此情形下这两种方案的形式化定义。

(b) Discuss how the attacks we have shown in this chapter can be modified to break these schemes.

(b) 讨论如何修改本章所展示的攻击，以破译这些方案。

1.7 The index of coincidence method relies on a known value for the sum of the squares of plaintext-letter frequencies (cf. Equation (1.1)). Why would it not work using the sum $\sum_i p_i$ itself?

重合指数法依赖于明文字母频率平方和的一个已知值（参见等式 (1.1)）。如果改用求和 $\sum_i p_i$ 本身，为什么就不管用了？

1.8 Show that the shift, substitution, and Vigenère ciphers are all trivial to break using a chosen-plaintext attack. How much chosen plaintext is needed to recover the key for each of the ciphers?

证明移位密码、替换密码和维吉尼亚密码用选择明文攻击都极易破译。对每种密码而言，恢复密钥需要多少选择明文？

1.9 Assume an attacker knows that a user's password is either abcd or bedg. Say the user encrypts his password using the shift cipher, and the attacker sees the resulting ciphertext. Show how the attacker can determine the user's password, or explain why this is not possible.

假设攻击者知道某用户的口令要么是 abcd，要么是 bedg。设该用户用移位密码加密自己的口令，而攻击者看到了所得密文。说明攻击者如何能确定该用户的口令，或者解释为什么这是不可能的。

1.10 Repeat the previous exercise for the Vigenère cipher using period 2, using period 3, and using period 4.

对维吉尼亚密码分别使用周期 2、周期 3 和周期 4，重复上一题。

1.11 The attack on the Vigenère cipher has two steps: (a) find the key length by identifying τ with $S_\tau \approx 0.065$ (cf. Equation (1.3)) and (b) for each character of the key, find j maximizing I_j (cf. Equation (1.2)), using $\{p_i\}$ corresponding to English text. What happens in each case if the underlying plaintext is in a language other than English?

对维吉尼亚密码的攻击分两步：（a）通过找出使 $S_\tau \approx 0.065$ 的 τ 来确定密钥长度（参见等式 (1.3)）；（b）对密钥的每个字符，找出使 I_j 最大的 j （参见等式 (1.2)），其中 $\{p_i\}$ 取与英文文本对应的值。如果底层明文使用的是英语以外的语言，在每种情况下会发生什么？